Educação Profissional Paulista

Técnico em
Desenvolvimento de Sistemas

GOVERNO DO ESTADO
DE SÃO PAULO

Integração contínua e entrega contínua

Entrega contínua (CD) – deploy automático em staging

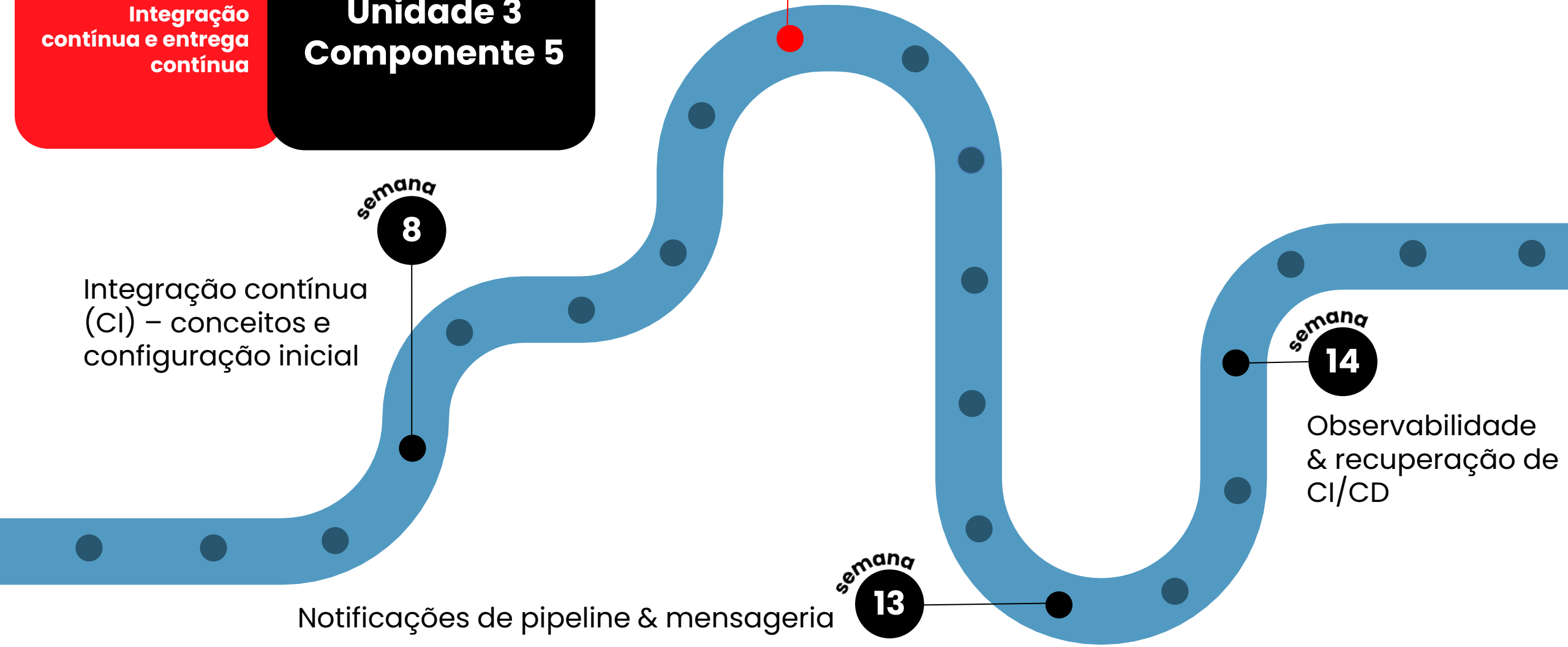
Aula 2: Configure-once, deploy-many – segredos e variáveis

Código da aula: SISANO2C5B2S9A2

GOVERNO DO ESTADO DE SÃO PAULO

Integração contínua e entrega contínua

Mapa da Unidade 3 Componente 5



Integração contínua e entrega contínua

Mapa da Unidade 3 Componente 5

Você está aqui!

Entrega contínua (CD) – deploy automático em staging

9

Aula 2: Configure-once, deploy-many – segredos e variáveis

Código da aula: SISANO2C5B2S9A2

Objetivos da aula

- Gerenciar segredos (tokens, chaves) no GitHub.

Recursos didáticos

- Recurso audiovisual para exibição de vídeos e imagens.
- Cadernos, canetas, lápis.
- Dispositivos para acesso à internet.
- Roteiro de atividade prática.

Duração da aula

50 minutos.

Habilidades técnicas

- Construir pipelines de entrega contínua para deploy automático e seguro em ambientes controlados.

Habilidades socioemocionais

- Demonstrar autoconfiança ao promover código para produção, assumindo responsabilidade pela estabilidade e qualidade das entregas.

Colocando em **prática**

Registro

Operação cofre digital: protegendo segredos na era do deploy automatizado

Materiais necessários

- Computador com ambiente de desenvolvimento.
- Editor de texto ou IDE para pseudocódigo.
- Cadernos, canetas, lápis.

Passo a passo

- Leiam com atenção a atividade proposta no roteiro.
- Antes de iniciar a codificação, realizem esboços no papel para definir a lógica.
- Utilizem as ferramentas de desenvolvimento disponíveis para implementar a atividade.
- Ao final, enviem um relatório com suas respostas.

Durante a aula

5 pessoas

PDF

Baixe o roteiro dessa atividade

Registro

Pause e **responda**

Qual é a principal vantagem do padrão “configure-once, deploy-many" em relação ao gerenciamento de secrets?

- Reduz o número de secrets necessários.
- Centraliza a configuração e reduz erros de deploy.
- Permite usar secrets iguais em todos os ambientes.
- Elimina a necessidade de máscaras de log.

Registro

Pause e **responda**

Qual é a principal vantagem do padrão “configure-once, deploy-many" em relação ao gerenciamento de secrets?

- ✗ Reduz o número de secrets necessários.
- ✓ Centraliza a configuração e reduz erros de deploy.
- ✗ Permite usar secrets iguais em todos os ambientes.
- ✗ Elimina a necessidade de máscaras de log.

O que nós **aprendemos hoje?**

Então ficamos assim...

1. O gerenciamento seguro de secrets funciona como um sistema de cofres digitais, onde informações sensíveis são armazenadas centralmente e distribuídas automaticamente para diferentes ambientes, sem exposição no código-fonte.

2. O padrão “configure once, deploy many” permite configurar secrets uma única vez no sistema de CI/CD e reutilizá-los em vários deploys, reduzindo erros manuais e aumentando a segurança operacional.

3. As máscaras de log são uma camada essencial de proteção que automaticamente oculta informações sensíveis nos logs do sistema, funcionando como um filtro de segurança que previne vazamentos acidentais mesmo quando outros controles falham.

Saiba mais

O que é CI/CD na prática

CI/CD é um processo que ajuda a automatizar testes e entregas de software. Ele é essencial para tornar os projetos mais rápidos, seguros e organizados. Aprender sobre CI/CD é um passo importante para quem quer entender como funciona o desenvolvimento profissional de sistemas.

ROBERT SILVA. O que é CI/CD? | DevOps. Youtube, 29 ago. 2023. Disponível em: https://www.youtube.com/watch?v=ZX0L6fHcBb4. Acesso em: 20 out. 2025.

Referências da aula

DOCKERDOCS. **Building best practices**, [s.d.]. Disponível em: https://docs.docker.com/develop/security-best-practices/. Acesso em: 20 out. 2025.

GITHUB. **Using secrets in GitHub Actions**, [s.d.]. Disponível em: https://docs.github.com/en/actions/security-guides/encrypted-secrets. Acesso em: 20 out. 2025.

OWASP. **OWASP Application Security Verification Standard (ASVS)**, [s.d.]. Disponível em: https://owasp.org/www-project-application-security-verification-standard/. Acesso em: 20 out. 2025.

Identidade visual: imagens © Getty Images.

Orientações ao Professor

GOVERNO DO ESTADO
DE SÃO PAULO

Slide 6

A seção *Colocando em prática* tem como objetivo aplicar os conhecimentos construídos durante a aula, incentivando a autonomia, o senso crítico e a criatividade dos estudantes. Nesse momento, os alunos consolidam o aprendizado por meio da prática orientada, simulando situações reais de desenvolvimento e segurança em ambientes de deploy.
Esta aula é prática e utiliza a analogia da **"Operação cofre digital"**. O professor deve atuar como um **"chefe de segurança"**, guiando os estudantes na construção de um sistema de deploy que protege informações sensíveis (secrets) em diferentes ambientes, seguindo o princípio **"configure-once, deploy-many"**.

Tempo previsto: 40 minutos.

Gestão da sala de aula:
- organize a turma de forma que todos tenham acesso aos computadores e possam acompanhar o roteiro passo a passo;
- circule entre os grupos, esclarecendo dúvidas e garantindo que as instruções sejam seguidas corretamente;
- reforce a importância da colaboração e da troca de ideias durante o processo;
- estimule os estudantes a relacionarem as práticas de segurança com os conceitos abordados anteriormente na aula.

Condução da dinâmica:
Configure-once, secrets e máscaras de log (10 minutos):

- explique o princípio **"configure-once, deploy-many"**, utilizando a analogia: "nós construímos um carro (uma imagem Docker) uma única vez. Depois, apenas mudamos as chaves (variáveis de ambiente e secrets) dependendo da garagem (ambiente) onde vamos estacioná-lo: DEV, STAGING ou PROD.";
- use o slide para diferenciar **variáveis de ambiente** (informações de configuração, não secretas) e **secrets** (informações sensíveis, como senhas e chaves de API);
- em seguida, introduza as **máscaras de log** como uma camada extra de segurança, explicando: "mesmo que o sistema use o secret corretamente, não queremos que ele apareça acidentalmente nos registros (logs). É como usar o cartão de crédito sem gritar o número em voz alta.".

Continua

Slide 6

Atividade "Colocando em prática" (30 minutos).
Esta é a atividade principal. O roteiro **"Operação cofre digital"** é detalhado e o papel do professor é atuar como facilitador.
Passo 1: peça para os alunos seguirem o roteiro, criando a estrutura do projeto e a aplicação Flask. Destaque o código **app.py**, mostrando onde as variáveis de ambiente e secrets serão consumidas (**os.getenv**).
Passo 2: ao chegar na parte do **Dockerfile**, explique a importância de criar um usuário não-root (appuser) como boa prática de segurança.
Passo 3: a configuração dos **secrets no GitHub** é o ponto central da aula. Projete essa etapa e mostre onde, nas configurações do repositório, os secrets de **PROD** e **STAGING** são criados. Enfatize que, uma vez salvos, eles não podem mais ser visualizados, apenas utilizados.
Passo 4: ao analisar o **workflow do GitHub Actions (deploy.yml)**, destaque como o mesmo artefato (imagem Docker) é utilizado nos jobs **deploy-staging** e **deploy-production**, mas os secrets são injetados de forma diferente (**${{ secrets.STAGING_DB_HOST }}** vs **${{ secrets.PROD_DB_HOST }}**). Explique que isso representa o **"configure-once, deploy-many"** em ação.
Passo 5: permita que os alunos executem o workflow e observem os logs, que devem exibir os secrets mascarados.

Expectativas de respostas: espera-se que os estudantes demonstrem compreensão dos princípios de segurança aplicados a pipelines de deploy, reconheçam a importância da gestão adequada de secrets e entendam o papel das máscaras de log como salvaguarda final em processos automatizados.

1. Por que nunca colocar secrets no código?
"Colocar um secret no código é como tatuar a senha do seu banco na testa. Qualquer pessoa que tiver acesso ao código-fonte (desenvolvedores ou, pior, o público, se o repositório for vazado) terá acesso irrestrito ao seu sistema. Secrets devem ser gerenciados fora do código, em um 'cofre' seguro, como o sistema de secrets do GitHub."
2. Como "configure-once, deploy-many" melhora a segurança?
"Esse princípio garante que o 'produto' (a imagem Docker) é exatamente o mesmo em todos os ambientes. A única coisa que muda são as configurações externas (secrets e variáveis). Isso melhora a segurança porque reduz drasticamente o risco de um secret de produção vazar acidentalmente no ambiente de desenvolvimento e vice-versa. Cada ambiente tem seu próprio 'cofre' e o acesso é rigorosamente controlado pelo pipeline."
3. Por que máscaras de log são essenciais?
"Mesmo que a aplicação use um secret de forma segura, um erro ou comando de debug pode acidentalmente imprimir esse secret nos arquivos de log. Logs são frequentemente acessados por mais pessoas e sistemas, tornando-se um ponto de vulnerabilidade. Máscaras de log são a última linha de defesa, garantindo que, mesmo que um secret 'escape', ele seja ofuscado e se torne inútil para um invasor."

Slides 7 e 8

Tempo previsto: 2 minutos para as respostas e 1 minuto para a correção.

Alternativa correta: Centraliza a configuração e reduz erros de deploy.
Feedback geral da atividade: Resposta correta! Ao construir o artefato uma vez e apenas injetar configurações diferentes, eliminamos erros causados por inconsistências entre ambientes e centralizamos o gerenciamento de secrets, tornando o processo mais seguro e confiável.

Slide 9

A seção **O que nós aprendemos hoje?**

Tempo previsto: 2 minutos.

Slide 10

A seção **Saiba mais**.

Tempo previsto: 1 minuto.

Educação Profissional Paulista

Técnico em
Desenvolvimento de Sistemas

GOVERNO DO ESTADO
DE SÃO PAULO